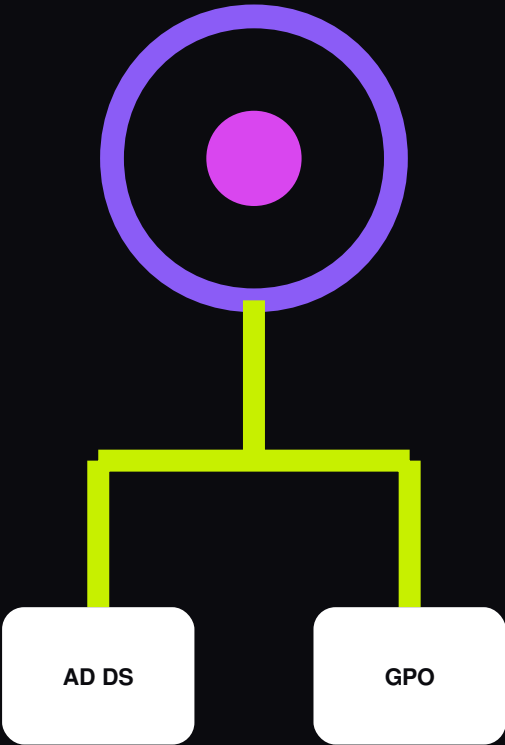


DOMAIN-ROOT GPO CHANGE TELEMETRY

Validates collection and raw representation of Active Directory object creation and modification events before detecting groupPolicyContainer creation or domain-root gPLink changes.

VALIDATION QUERY

CONFIDENCE: MEDIUM



EVIDENCE BEFORE ALERTING

REPORT DATE	STATUS
28 September 2026	Untested implementation sketch
PRIMARY PLATFORM	OPERATIONAL VALUE
Microsoft Sentinel	9.8 / 10



EXECUTIVE ASSESSMENT

Decision, confidence and evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

9.8

Validates collection and raw representation of Active Directory object creation and modification events before detecting groupPolicyContainer creation or domain-root gPLink changes.

STATUS

Validation query

Untested implementation sketch; Confidence Medium.

1primary table

0joins

0secondary rules

2validation gates

Evidence boundary

A returned 5136 or 5137 row proves only that Directory Service audit telemetry was collected. It does not prove malicious GPO creation, domain-root linkage, policy application, impact, exfiltration, or PAYLOAD attribution.



BEHAVIOR AND EVIDENCE

Observed facts separated from analytical scope.

MECHANICS

Source-supported fact

- 1 Kaspersky observed an actor create the PAYLOAD GPO and link it at the domain root after obtaining domain-admin-equivalent control.
- 2 The actor staged payload.jpg and hello.txt in SYSVOL and linked a second GPO that disabled Windows Firewall across profiles.
- 3 No encryptor binary or endpoint persistence was observed; impact logic resided in Group Policy configuration.

Detection hypothesis

If an attacker creates a GPO and modifies the domain-root gPLink, Windows Security telemetry should expose 5137 creation and 5136 attribute changes. Distinction requires verified raw fields, sensitive scope, authorized administrators, and change records.

Unconfirmed elements

A returned 5136 or 5137 row proves only that Directory Service audit telemetry was collected. It does not prove malicious GPO creation, domain-root linkage, policy application, impact, exfiltration, or PAYLOAD attribution.

Logic: Behavioral telemetry validation **ATT&CK:** T1484.001



TELEMETRY CONTRACT

Collection prerequisites and field reliability.

TELEMETRY

REQUIRED

Windows Security Events via AMA from every domain controller; Audit Directory Service Changes (Success); appropriate SACLs; a DCR that includes Event IDs 5136 and 5137.

OPTIONAL ENRICHMENT

Authorized GPO administrator inventory, change tickets, domain and sensitive-OU distinguished names, GPO GUID resolution, SYSVOL file telemetry, VPN context, and endpoint policy-application evidence.

Fields	Reliability	Use
TimeGenerated, Computer, EventID	Documented	Query or triage
EventSourceName, Activity	Documented	Query or triage
SubjectAccount, SubjectUserName	Documented	Query or triage
SubjectDomainName, SubjectUserSid	Documented	Query or triage
SubjectLogonId, EventData	Documented	Query or triage
ObjectDN, ObjectClass	Official event XML; validate mapping	Query or triage
AttributeLDAPDisplayName, Value	Official event XML; validate mapping	Query or triage
OperationType, OpCorrelationID	Official event XML; validate mapping	Query or triage

Excluded

No policy application, file content, impact, exfiltration, malicious intent, actor attribution, or undocumented cross-SIEM mapping is inferred from these audit rows.



PRIMARY KQL

Direct source-supported conditions with investigable output.

VALIDATION

STATUS

Validation query — Untested implementation sketch

KQL — UNTESTED

```
SecurityEvent
| where EventSourceName == "Microsoft-Windows-Security-Auditing"
| where EventID in (5136, 5137)
| project TimeGenerated, Computer, EventID, Activity,
        SubjectAccount, SubjectUserName, SubjectDomainName,
        SubjectUserSid, SubjectLogonId, EventData
| order by TimeGenerated desc
```

WINDOW

None; analyst-selected search range

THRESHOLD

None

JOIN

None

KEY

Future:
OpCorrelationID / ObjectGUID



TRIAGE AND TUNING

Human validation before response.

WORKFLOW

1

Preserve

Retain the raw Windows event XML, Sentinel EventData, domain controller, actor SID/account, timestamps, object identifiers, attribute values, and correlation IDs.

2

Confirm

Identify the GPO administrator, change record, target domain or OU, GPO GUID/display name, and policy owner.

3

Enrich

Authorized GPO administrator inventory, change tickets, domain and sensitive-OU distinguished names, GPO GUID resolution, SYSVOL file telemetry, VPN context, and endpoint policy-application evidence.

4

Scope

Review adjacent GPO creation/link changes, SYSVOL writes, VPN and logon evidence, endpoint policy application, firewall state, and impact artifacts.

Expected benign overlap

Legitimate Group Policy administration, automation, security baselines, deployments, and recovery operations produce the same event families. Future tuning must use verified object DN, LDAP attribute, actor ownership, and change records; campaign names, GUIDs, rarity, and arbitrary counts are not durable conditions.

Response boundary

A returned 5136 or 5137 row proves only that Directory Service audit telemetry was collected. It does not prove malicious GPO creation, domain-root linkage, policy application, impact, exfiltration, or PAYLOAD attribution.



VALIDATION GATES

Controlled tests and cross-SIEM limits.

QUALITY CONTROL

Validation steps

1. Enable Audit Directory Service Changes (Success) and suitable SACLs in a lab; confirm the Sentinel DCR includes 5136 and 5137.
2. Create a benign GPO, link it to a test OU, then modify and remove the link while recording the approved actor and change ticket.
3. Verify every relevant domain controller returns actor fields and raw EventData; document exact ObjectDN, ObjectClass, LDAP attribute, value, operation, and correlation-ID representation.
4. Measure authorized administrative overlap before designing separate rules for gPLink modification and groupPolicyContainer creation.

Decision criteria

Success: All relevant domain controllers ingest interpretable 5136/5137 events, and the benign test exposes exact actor, target, attribute, operation, value, and correlation context.

Rejection: EventData cannot distinguish gPLink or groupPolicyContainer semantics, or authorized activity cannot be reliably attributed and tuned.

Failure: Audit policy or SACLs are absent, the DCR uses Minimal collection, a domain controller is not covered, EventData is truncated, or Windows Event Forwarding routes data to WindowsEvent instead.

Platform	Decision	Missing evidence
Defender XDR	Validation query	Directory Service audit validation
Splunk	No reliable implementation	Index, sourcetype, parser, sample
Chronicle	No reliable implementation	Parser and exact UDM mapping



CONCLUSION AND REFERENCES

Coverage statement and document control.

FINAL

CONCLUSION

Validation query

Validates collection and raw representation of Active Directory object creation and modification events before detecting groupPolicyContainer creation or domain-root gPLink changes.

A returned 5136 or 5137 row proves only that Directory Service audit telemetry was collected. It does not prove malicious GPO creation, domain-root linkage, policy application, impact, exfiltration, or PAYLOAD attribution.

MITRE ATT&CK

T1484.001

References

1. Kaspersky Securelist — PAYLOAD ransomware via Group Policy — 21 Sep 2026; incident 11-16 Apr 2026
2. Microsoft Learn — SecurityEvent schema — updated 27 Aug 2026
3. Microsoft Learn — Events 5136 and 5137; Audit Directory Service Changes
4. Microsoft Sentinel — Windows security event sets — updated 28 Aug 2026

Document control

English dossier. No customer data. URLs are defanged in references.txt. HTML and rendering assets remain private.